Lab 5: Static Code Analysis

Electricity Bill Calculator

Shriya Vasundhara Singh | PES1UG24AM269

27 October 2026

Objective and scope

Analyze the assigned electricity billing program using Pylint, Bandit and Flake8; fix the findings while preserving the supplied billing demonstration. The updated source fixes ten documented issue groups and includes three tool-focused commits.

Measured results

Tool	Before	After
Pylint	5.44/10; 26 messages	10.00/10; no messages
Bandit	4: 1 high, 1 medium, 2 low	0 findings
Flake8	4 violations	0 violations

Method and tool environment

The repository was cloned from SETAPESU26/L5_30_electricity_bill at a48c8e9fe56e72e1d809174a23ec2e96a67dd48e. The original demo and tool outputs were captured before editing. Checks ran on Python 3.13 with Pylint 4.1.3, Bandit 1.9.4, Flake8 7.4.1 and defusedxml 0.7.1. Full dependency versions are recorded in requirements-dev.txt.

Before and after reports are in reports/before and reports/after. Each folder includes exact commands, exit statuses and stderr. All final tool exits are zero; no lint or security rules were suppressed. Flake8 produces an empty report when successful.

Preserved billing results

M1: Rs. 708.75 | M2: Rs. 2,661.75 | M3: Rs. 78.75 | M4: Rs. 288.75. Highest bill: M2. Average: Rs. 934.50. Total: Rs. 3,738.00. The backwards-reading warning, terminal output and saved JSON values match the original.

Issue table

Original-source line numbers are used below. Bandit severity and Pylint message categories are shown as reported; style warnings are not presented as security vulnerabilities.

Issue / tool / lines	Description	Fix approach
Shell command injection Bandit B605 / High Lines 61-63	A meter address is concatenated into an os.system command.	Use an HTTPS client directly, validate an IP literal, set a timeout, and close the connection in finally.
Unsafe XML parsing Bandit B314 / Medium Lines 18	ElementTree.fromstring accepts untrusted XML without hardening.	Use defusedxml.ElementTree.fromstring; verify entity input is rejected.
Unsafe XML import Bandit B405 / Low Lines 3	The standard XML parser import is flagged for untrusted input.	Replace the import with defusedxml and declare its dependency.
Hard-coded password Bandit B105 / Low Lines 13	An unused password literal is stored in source.	Remove the unused credential; the program has no authentication flow.
Mutable default argument Pylint W0102 / Warning Lines 42	extras={} creates a shared default dictionary. It is not mutated by the original function, but is a risky default for later changes.	Default extras to None and create a fresh dictionary inside the function.
Unused parameter Pylint W0613 / Warning Lines 50	The currency argument has no effect on averageBill.	Remove the argument and update its caller; billing remains in rupees.
Unspecified encoding Pylint W1514 / Warning Lines 57	JSON output relies on the operating system default encoding.	Open the output file with encoding="utf-8".
Nonstandard names Pylint C0103 / Convention Lines 17-76	Functions, arguments and local variables use camelCase.	Use snake_case names consistently and update internal callers.
Missing documentation Pylint C0114/C0116 / Convention Lines 1,17-66	The module and functions lack descriptions.	Add concise module and function docstrings.
PEP 8 formatting Flake8 E302/E203/E501/E225 Lines 22,44,72,76	Missing blank line, whitespace before a colon, an 86-character line and missing operator spacing.	Use two blank lines between functions, correct spacing and wrap long statements below 80 characters.

Additional review fixes: the entry-point guard prevents execution during import, and clearing BILLS makes repeated demos consistent. These were not claimed as findings in the original tool reports.

Validation and commit evidence

Ten regression tests passed. Checks covered slab boundaries (0, 50, 100, 150, 200, 300, 301 and 420 units), reversed readings, tax and fees, empty averages, JSON persistence, safe import, rejected XML entities, rejected shell-like addresses, HTTPS request handling and connection cleanup on HTTP error. The original and final demo stdout and JSON values were equal.

Three fix commits

1. fix: resolve Bandit security findings - remove the shell invocation and unused password, harden XML parsing.

2. fix: address Pylint quality and correctness findings - add docstrings, rename identifiers, remove the mutable default and unused argument, specify UTF-8 and guard the demo.

3. fix: resolve Flake8 formatting and finalize lab deliverables - correct spacing and line lengths, include final reports, documentation and test evidence. The local Git history and commit_history.txt provide the exact hashes.

Limits and behavior changes

The sync helper now accepts an IP literal and uses verified HTTPS with a timeout; it returns response bytes. This requires a meter with HTTPS and a trusted certificate matching the IP. No live meter was tested; network behavior was mocked. Renamed functions and the removed currency argument require updates to external callers. The supplied demo remains unchanged.

Reflection

The supplied PDF refers to reflection questions but does not show their wording. These four clearly labelled topics address the lab objectives; they are not quoted questions from the handout.

What did the three tools contribute?

Pylint identified quality problems such as the mutable default, unused currency parameter, missing documentation and inconsistent names. Bandit found the shell command, unsafe XML parser and stored password. Flake8 found spacing, blank-line and line-length violations. Using all three covered more problems than using only one.

Which issues were prioritized, and why?

The high-severity B605 finding was addressed first because the meter address could become shell instructions. Medium-severity B314 was next because XML can contain malicious entities. The two low-severity Bandit findings were also fixed before quality and style cleanup.

How was correctness checked after the fixes?

The original and final demos were compared using captured terminal output and parsed JSON. Both produced M1=708.75, M2=2661.75, M3=78.75 and M4=288.75, with total 3738.00 and average 934.50. Regression checks covered slab boundaries, reversed readings, fees, JSON storage, import behavior, XML entities and mocked meter requests.

What are the benefits and limits of static analysis?

Static analysis makes suspicious patterns and inconsistent style visible early, improving maintainability and review. A clean report does not prove correctness or complete security. Tests and human review are still needed. The HTTPS helper was checked with mocks; no real meter endpoint was available for an integration test.